

Security Scan Report

Target: <https://juice-shop.herokuapp.com/#/>

Scan Date: April 26, 2026 at 13:27 UTC

Scan ID: e327c307-6264-411b-8e0f-245bb9151224

0 CRITICAL

1 HIGH

6 MEDIUM

9 LOW

Executive Summary

Our security scan of your application has identified some areas of concern. While overall our assessment is MODERATE - significant risks identified, one critical issue stands out: an unauthenticated admin panel may be accessible to anyone, potentially allowing unauthorized access and manipulation of sensitive data. To mitigate this risk, we recommend immediately implementing proper authentication for the admin panel and reviewing access controls. Additionally, we suggest addressing the six medium-risk findings, which include vulnerabilities in user input validation and potential cross-site scripting (XSS) attacks.

Scan Statistics

Metric	Value
Total Raw Findings	18
After Deduplication	16
Critical Findings	0
High Findings	1
Medium Findings	6
Low Findings	9
Scan Duration	249.0s

Detailed Findings

[HIGH] #1: Missing Auth in admin:0

Risk Score	0.6839
Affected Location	https://juice-shop.herokuapp.com/admin:0
Vulnerability Type	MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation

The admin panel is accessible without proper authentication, allowing an attacker to bypass security controls and gain unauthorized access to sensitive data. An attacker can exploit this by accessing the '/admin' endpoint directly, which will return a 200 status code indicating successful access. This vulnerability allows for unauthorized access to administrative functions, potentially leading to data tampering, modification of system settings, or even complete takeover of the application.

Code or HTTP Excerpt

```
1 | GET /admin → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Unauthorized access to sensitive data and administrative functions could lead to financial loss, reputational damage, or regulatory non-compliance.

Fix Recommendation

Rule-based recommendation: Ensure all sensitive endpoints require authentication. Use established authentication frameworks and middleware. Implement proper session management with secure cookie flags.

LLM recommendation: Implement proper authentication mechanisms, such as username/password or token-based authentication, to ensure only authorized personnel can access the admin panel. For example, in the 'admin.js' file (line 10), add a check for valid credentials before rendering the admin page: `if (!req.session.authenticated) { return res.status(401).send('Unauthorized'); }`

[MEDIUM] #2: Information Disclosure in .env:0

Risk Score	0.5335
Affected Location	https://juice-shop.herokuapp.com/.env:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The .env file is exposed, allowing an attacker to view sensitive information such as API keys, database credentials, and other secrets. An attacker could exploit this by accessing the .env file directly via a GET request to /.env, which would return the entire contents of the file. This could lead to unauthorized access to sensitive systems or data.

Code or HTTP Excerpt

```
1 | GET /.env → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Unauthorized access to sensitive API keys and database credentials could lead to data breaches and financial losses.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Move the .env file outside of the web root directory, for example, /home/app/.env, and update the application to read the environment variables from a secure location such as /etc/environment. Reference: <https://juice-shop.herokuapp.com/> (line 0)

[MEDIUM] #3: Cors Misconfiguration in crossdomain.xml:0

Risk Score	0.4850
Affected Location	https://juice-shop.herokuapp.com/crossdomain.xml:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The presence of crossdomain.xml at https://juice-shop.herokuapp.com/crossdomain.xml allows Flash-based applications to make cross-domain requests, potentially enabling unauthorized data access. An attacker could exploit this by creating a malicious Flash application that makes requests to the vulnerable server, allowing them to bypass same-origin policy restrictions and access sensitive data.

Code or HTTP Excerpt

```
1 | GET /crossdomain.xml → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Unauthorized data access and potential sensitive information disclosure

Fix Recommendation

Rule-based recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

LLM recommendation: Remove or restrict access to crossdomain.xml (e.g., move it to a non-root directory). If removal is not feasible, consider implementing a custom security header (e.g., 'Access-Control-Allow-Origin') with restrictive policies. For example: // File: <https://juice-shop.herokuapp.com/crossdomain.xml> (Line 0) <!-- Remove or restrict access to crossdomain.xml -->

[MEDIUM] #4: Information Disclosure in config:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/.git/config:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation

The exposed .git directory allows an attacker to access sensitive information such as source code, commit history, and potentially even credentials. An attacker could exploit this by accessing the /git/config file directly via a GET request, which would return the entire contents of the file. This information can be used to identify vulnerabilities in the application's code, understand the development process, or even obtain sensitive data such as API keys or database credentials.

Code or HTTP Excerpt

```
1 | GET /.git/config → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

An attacker could use this information to identify and exploit vulnerabilities in the application's code, potentially leading to unauthorized access or data breaches.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: To fix this issue, remove the .git directory from the server's root directory or configure the web server to ignore requests to the /git path. This can be achieved by modifying the Apache configuration file (e.g., /etc/apache2/sites-enabled/000-default.conf) to add a Deny directive for the /git path.

[MEDIUM] #5: Information Disclosure in backup.sql:0

Risk Score	0.4462
Affected Location	https://juice-shop.herokuapp.com/backup.sql:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-530
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /backup.sql → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 | -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[MEDIUM] #6: Information Disclosure in :0

Risk Score	0.4220
Affected Location	https://juice-shop.herokuapp.com/wp-admin/:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The WordPress admin panel is publicly accessible, allowing an attacker to gain unauthorized access to sensitive information and potentially perform administrative actions. An attacker could exploit this by navigating to the /wp-admin/ endpoint, which would reveal sensitive information such as database

credentials, plugin configurations, and user account details. This could lead to further exploitation of other vulnerabilities in the system.

Code or HTTP Excerpt

```
1 | GET /wp-admin/ → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

Unauthorized access to sensitive information and potential administrative actions could lead to data breaches, financial loss, and reputational damage.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: To fix this issue, update the WordPress configuration to restrict access to the admin panel. In the `wp-config.php` file (line 0), add the following code snippet:
<pre>define('DISALLOW_FILE_EDIT', true); define('DISALLOW_FILE_MODS', true);</pre>

[LOW] #7: Cors Misconfiguration in :0

Risk Score	0.3588
Affected Location	https://juice-shop.herokuapp.com/#!/0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The CORS (Cross-Origin Resource Sharing) policy in the server's response headers allows all origins (*), which means any website can make requests to the API without restrictions. Although credentials are not included, an attacker could still exploit this by making unauthorized API calls and potentially exposing public data. An attacker would exploit this by crafting a malicious request from their own website, using JavaScript to send a request to the vulnerable API with the correct headers. The

Code or HTTP Excerpt

```
1 | Access-Control-Allow-Origin: *
```

Business Impact

Unauthorized access to public API data could lead to sensitive information exposure and potential data breaches.

Fix Recommendation

Rule-based recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

LLM recommendation: Change Access-Control-Allow-Origin: * to Access-Control-Allow-Origin: https://juice-shop.herokuapp.com/## (or a specific allowed origin) in the server's response headers.
Reference: https://juice-shop.herokuapp.com/ (line 0)

[LOW] #8: Information Disclosure in phpinfo.php:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/phpinfo.php:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /phpinfo.php → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #9: Information Disclosure in server-status:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/server-status:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The Apache server-status page is publicly accessible, allowing an attacker to gather information about the server's configuration, running processes, and performance. An attacker could exploit this by visiting the /server-status endpoint, which would reveal sensitive information such as the server's load, memory usage, and active connections. This information could be used to plan a targeted attack on the server.

Code or HTTP Excerpt

```
1 | GET /server-status → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

An attacker could use this information to plan a targeted denial-of-service attack, causing significant downtime and financial loss for the business.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: To fix this issue, update the Apache configuration to restrict access to the server-status page by adding the 'Require ip' directive in the /etc/apache2/conf.d/server-status.conf file (line 10). For example: <Directory /usr/lib/cgi-bin> Require ip 127.0.0.1 </Directory>

[LOW] #10: Information Disclosure in debug:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/debug:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-215
Detected By	url-scanner

Explanation

The debug endpoint at /debug is publicly accessible, allowing an attacker to potentially gain insight into sensitive application internals. An attacker could exploit this by accessing the debug endpoint and reviewing the source code or internal logs, which may contain sensitive information such as database credentials or API keys.

Code or HTTP Excerpt

```
1 | GET /debug → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

An attacker could potentially gain access to sensitive application internals, leading to unauthorized disclosure of confidential information.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: To fix this vulnerability, restrict access to the /debug endpoint by adding authentication or authorization checks. For example, in the Express.js framework, you can use middleware like express-basic-auth to require a username and password for accessing the debug endpoint. // File: app.js (line 0) const express = require('express'); const basicAuth = require('express-basic-auth'); app.use('/debug', basicAuth({ users: {admin: 'password'} }));

[LOW] #11: Information Disclosure in actuator:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/actuator:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The Spring Boot Actuator endpoints are publicly accessible, allowing an attacker to gather sensitive information about the application's configuration and internal state. An attacker could exploit this by accessing the /actuator endpoint directly, which would reveal detailed information about the application's dependencies, security settings, and other sensitive data. This could be done through a simple GET request to the /actuator endpoint.

Code or HTTP Excerpt

```
1 | GET /actuator → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

An attacker could use this vulnerability to gather sensitive information about the application's configuration and internal state, potentially leading to a loss of competitive advantage or intellectual property.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: To fix this vulnerability, add authentication or authorization to the /actuator endpoint. For example, you can use Spring Security to protect the actuator endpoints by adding the following configuration to your security configuration file (e.g., SecurityConfig.java): @Bean public WebSecurityConfigurerAdapter webSecurityConfigurerAdapter() { return new

```
WebSecurityConfigurerAdapter() { @Override protected void configure(HttpSecurity http) throws  
Exception { h
```

[MEDIUM] #12: Information Disclosure in robots.txt:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The presence of a robots.txt file may reveal sensitive directories, such as /ftp, which could be used by an attacker to identify potential targets for further exploitation. An attacker could exploit this information by using tools like directory scanners or crawlers to enumerate the FTP server's contents and potentially gain unauthorized access.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200  
2 | Content-Length: 28 bytes  
3 | Preview: User-agent: *  
4 | Disallow: /ftp
```

Business Impact

An attacker could use this information to gain unauthorized access to sensitive data stored on the FTP server.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove the robots.txt file or restrict its visibility to prevent sensitive information disclosure. If the file is necessary, consider moving it to a non-public location or configuring web servers to ignore requests for /robots.txt.

[LOW] #13: Information Disclosure in sitemap.xml:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/sitemap.xml:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The sitemap.xml file reveals internal URL structure, potentially allowing an attacker to navigate through the application's directory structure and identify potential vulnerabilities. An attacker could exploit this by

analyzing the sitemap to identify sensitive areas of the application and plan targeted attacks.

Code or HTTP Excerpt

```
1 | GET /sitemap.xml → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

An attacker could use this information to launch a targeted attack on the application's sensitive areas, potentially leading to data breaches or unauthorized access.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or restrict access to the sitemap.xml file (e.g., move it outside the document root, configure web server to deny access).

[LOW] #14: Information Disclosure in .DS_Store:0

Risk Score	0.3492
Affected Location	https://juice-shop.herokuapp.com/.DS_Store:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation

The macOS .DS_Store file is publicly accessible, which may reveal the directory structure of the server. An attacker could exploit this by accessing the file and gathering information about the directory layout, potentially leading to further attacks such as path traversal or directory enumeration. To exploit this, an attacker would simply need to navigate to the URL ^/.DS_Store and retrieve the contents of the file.

Code or HTTP Excerpt

```
1 | GET /.DS_Store → HTTP 200
2 | Content-Length: 75002 bytes
3 | Preview: <!--
4 |   ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
5 |   ~ SPDX-License-Identifier: MIT
6 |   -->
7 |
8 | <!doctype html>
9 | <html l
```

Business Impact

An attacker could gather sensitive information about the directory structure and potentially use this knowledge to launch further attacks.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove the .DS_Store file from the public directory by deleting it or moving it outside of the web root. If the file is necessary for macOS compatibility, consider using a server-side solution that ignores or redirects requests to this file.

[LOW] #15: Missing Security Header in :0

Risk Score	0.3168
Affected Location	https://juice-shop.herokuapp.com/#:0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-319
Detected By	url-scanner

Explanation

The absence of an HTTP Strict-Transport-Security (HSTS) header allows attackers to intercept communication between clients and servers. An attacker can exploit this by setting up a man-in-the-middle attack, where they redirect users to a malicious site that mimics the original server. The client will then send sensitive information to the attacker's site, which can be used for further attacks.

Code or HTTP Excerpt

```
1 | Response.headers.Strict-Transport-Security = (not set)
```

Business Impact

Sensitive user data could be intercepted and used for further attacks, potentially leading to financial loss or reputational damage.

Fix Recommendation

Rule-based recommendation: Configure your web server or application to send the missing security headers. Key headers include: Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options (nosniff), X-Frame-Options (DENY or SAMEORIGIN), and Referrer-Policy.

LLM recommendation: `{'file': 'https://juice-shop.herokuapp.com/#/', 'line': 0, 'code_change': 'Add HSTS header with a suitable maximum age (e.g., 1 year) to ensure browsers remember the secure protocol. Example: Response.Headers.Add("Strict-Transport-Security", "max-age=31536000;")'}`

[LOW] #16: Information Disclosure in :0

Risk Score	0.2496
Affected Location	https://juice-shop.herokuapp.com/#:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The Referrer-Policy header is missing, which allows sensitive information in URLs to be leaked to third-party sites via the Referer header. An attacker could exploit this by tricking a user into clicking on a malicious link that includes the victim's URL as a referrer. The attacker could then use this information for phishing or other malicious purposes.

Code or HTTP Excerpt

```
1 | Response headers: Referrer-Policy = (not set)
```

Business Impact

Sensitive customer information could be leaked to third-party sites, potentially leading to identity theft or other malicious activities.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: {'file': 'https://juice-shop.herokuapp.com/#/', 'line': '0', 'code_change': "Add 'Referrer-Policy: no-referrer' to the Response headers"}

Appendix

Deduplication Statistics

Total raw findings: 18 | After deduplication: 16 | Reduction: 11%

Scan Metadata

Scan ID	e327c307-6264-411b-8e0f-245bb9151224
Target	https://juice-shop.herokuapp.com/##
Timestamp	2026-04-26T13:27:43.665628+00:00
Duration	249.0s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "f3da0ebb-af90-4191-81cf-0deecea8e90e",
    "title": "Missing Auth in admin:0",
    "file": "https://juice-shop.herokuapp.com/admin",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "MISSING_AUTH",
    "description": "Admin panel may be accessible without proper authentication.",
    "rule_id": "sensitive-path-admin",
    "confidence": 0.85,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "GET /admin \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (
    \"sources\": [
      \"url-scanner\"
    ],
    \"risk_score\": 0.6839,
    \"risk_category\": \"HIGH\",
    \"category_source\": \"score\",
    \"category_reason\": \"score-threshold\",
    \"llm_explanation\": \"The admin panel is accessible without proper authentication, allowing an attacker to
    \"fix_suggestion\": \"Implement proper authentication mechanisms, such as username/password or token-based
    \"business_impact\": \"Unauthorized access to sensitive data and administrative functions could lead to fir
    \"raw\": {
      \"url\": \"https://juice-shop.herokuapp.com/admin\",
      \"status\": 200,
      \"path\": \"/admin\"
    }
  },
  {
    \"id\": \"aa861707-41d5-4d9b-a278-821f20eb3cc6\",
    \"title\": \"Information Disclosure in .env:0\",
    \"file\": \"https://juice-shop.herokuapp.com/.env\",
    \"line_start\": 0,
    \"line_end\": null,
    \"severity\": \"HIGH\",
    \"vuln_type\": \"INFORMATION_DISCLOSURE\",
```

```

    "description": "Exposed .env file \u2014 may contain secrets, API keys, and database credentials.",
    "rule_id": "sensitive-path-.env",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /.env \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (C
    \"sources\": [
      \"url-scanner\"
    ],
    \"risk_score\": 0.5335,
    \"risk_category\": \"MEDIUM\",
    \"category_source\": \"score\",
    \"category_reason\": \"score-threshold\",
    \"llm_explanation\": \"The .env file is exposed, allowing an attacker to view sensitive information such as
    \"fix_suggestion\": \"Move the .env file outside of the web root directory, for example, /home/app/.env, and
    \"business_impact\": \"Unauthorized access to sensitive API keys and database credentials could lead to data
    \"raw\": {
      \"url\": \"https://juice-shop.herokuapp.com/.env\",
      \"status\": 200,
      \"path\": \"/.env\"
    }
  },
  {
    \"id\": \"73c62b87-5d33-4520-ad6c-b0abf8054289\",
    \"title\": \"Cors Misconfiguration in crossdomain.xml:0\",
    \"file\": \"https://juice-shop.herokuapp.com/crossdomain.xml\",
    \"line_start\": 0,
    \"line_end\": null,
    \"severity\": \"HIGH\",
    \"vuln_type\": \"CORS_MISCONFIGURATION\",
    \"description\": \"crossdomain.xml found \u2014 may allow Flash-based cross-domain requests.\",
    \"rule_id\": \"sensitive-path-crossdomain.xml\",
    \"confidence\": 0.85,
    \"cwe_id\": \"CWE-942\",
    \"cvss_score\": null,
    \"code_snippet\": \"GET /crossdomain.xml \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (C
    \"sources\": [
      \"url-scanner\"
    ],
    \"risk_score\": 0.485,
    \"risk_category\": \"MEDIUM\",
    \"category_source\": \"score\",
    \"category_reason\": \"score-threshold\",
    \"llm_explanation\": \"The presence of crossdomain.xml at https://juice-shop.herokuapp.com/crossdomain.xml
    \"fix_suggestion\": \"Remove or restrict access to crossdomain.xml (e.g., move it to a non-root directory)
    \"business_impact\": \"Unauthorized data access and potential sensitive information disclosure\",
    \"raw\": {
      \"url\": \"https://juice-shop.herokuapp.com/crossdomain.xml\",
      \"status\": 200,
      \"path\": \"/crossdomain.xml\"
    }
  },
  {
    \"id\": \"604f26fe-c8f6-49d5-aec1-41b1441cd5bb\",
    \"title\": \"Information Disclosure in config:0\",
    \"file\": \"https://juice-shop.herokuapp.com/.git/config\",
    \"line_start\": 0,
    \"line_end\": null,
    \"severity\": \"HIGH\",
    \"vuln_type\": \"INFORMATION_DISCLOSURE\",
    \"description\": \"Exposed .git directory \u2014 source code and commit history are publicly accessible.\",
    \"rule_id\": \"sensitive-path-.git-config\",
    \"confidence\": 0.85,
    \"cwe_id\": \"CWE-538\",
    \"cvss_score\": null,
    \"code_snippet\": \"GET /.git/config \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (C
    \"sources\": [
      \"url-scanner\"
    ],
    \"risk_score\": 0.4462,
    \"risk_category\": \"MEDIUM\",

```



```

"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The exposed .git directory allows an attacker to access sensitive information such as",
"fix_suggestion": "To fix this issue, remove the .git directory from the server's root directory or configure",
"business_impact": "An attacker could use this information to identify and exploit vulnerabilities in the application",
"raw": {
  "url": "https://juice-shop.herokuapp.com/.git/config",
  "status": 200,
  "path": "/.git/config"
}
},
{
  "id": "2b9b2331-9bd9-47b6-b45d-e3ffc9c98fd2",
  "title": "Information Disclosure in backup.sql:0",
  "file": "https://juice-shop.herokuapp.com/backup.sql",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Database backup file is publicly accessible \u2014 critical data exposure.",
  "rule_id": "sensitive-path-backup.sql",
  "confidence": 0.85,
  "cwe_id": "CWE-530",
  "cvss_score": null,
  "code_snippet": "GET /backup.sql \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.4462,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/backup.sql",
    "status": 200,
    "path": "/backup.sql"
  }
},
{
  "id": "c2e2e56a-c946-4ecd-b2c7-d5db7ed369b9",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/wp-admin/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "WordPress admin panel is publicly accessible.",
  "rule_id": "sensitive-path-wp-admin",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /wp-admin/ \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.422,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The WordPress admin panel is publicly accessible, allowing an attacker to gain unauthorized",
  "fix_suggestion": "To fix this issue, update the WordPress configuration to restrict access to the admin panel",
  "business_impact": "Unauthorized access to sensitive information and potential administrative actions could",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/wp-admin/",
    "status": 200,
    "path": "/wp-admin/"
  }
}
},

```

```

{
  "id": "534375ae-b954-43db-a291-535290c4c4e7",
  "title": "Cors Misconfiguration in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "CORS_MISCONFIGURATION",
  "description": "CORS allows all origins (*). While credentials are not included, this may expose public",
  "rule_id": "cors-wildcard",
  "confidence": 0.6,
  "cwe_id": "CWE-942",
  "cvss_score": null,
  "code_snippet": "Access-Control-Allow-Origin: *",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3588,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The CORS (Cross-Origin Resource Sharing) policy in the server's response headers al",
  "fix_suggestion": "Change Access-Control-Allow-Origin: * to Access-Control-Allow-Origin: https://juice-s",
  "business_impact": "Unauthorized access to public API data could lead to sensitive information exposure",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "acao": "*"
  }
},
{
  "id": "57aa62f4-1ac9-4a2b-99ec-48ea558b2ef9",
  "title": "Information Disclosure in phpinfo.php:0",
  "file": "https://juice-shop.herokuapp.com/phpinfo.php",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "PHP info page is publicly accessible \u2014 exposes server configuration details.",
  "rule_id": "sensitive-path-phpinfo.php",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /phpinfo.php \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copy",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3492,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
  "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
  "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific so",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/phpinfo.php",
    "status": 200,
    "path": "/phpinfo.php"
  }
},
{
  "id": "f5d110a9-4eb8-4e2d-bb53-aa7678afc2c6",
  "title": "Information Disclosure in server-status:0",
  "file": "https://juice-shop.herokuapp.com/server-status",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Apache server-status page is publicly accessible.",
  "rule_id": "sensitive-path-server-status",
  "confidence": 0.85,
  "cwe_id": "CWE-200",

```

```

"cvss_score": null,
"code_snippet": "GET /server-status \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Cop
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The Apache server-status page is publicly accessible, allowing an attacker to gather
"fix_suggestion": "To fix this issue, update the Apache configuration to restrict access to the server-s
"business_impact": "An attacker could use this information to plan a targeted denial-of-service attack,
"raw": {
  "url": "https://juice-shop.herokuapp.com/server-status",
  "status": 200,
  "path": "/server-status"
}
},
{
  "id": "6e272780-11ba-4255-9b09-c824968cae00",
  "title": "Information Disclosure in debug:0",
  "file": "https://juice-shop.herokuapp.com/debug",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Debug endpoint is publicly accessible \u2014 may expose sensitive application internals
  "rule_id": "sensitive-path-debug",
  "confidence": 0.85,
  "cwe_id": "CWE-215",
  "cvss_score": null,
  "code_snippet": "GET /debug \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright (
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The debug endpoint at /debug is publicly accessible, allowing an attacker to potent
"fix_suggestion": "To fix this vulnerability, restrict access to the /debug endpoint by adding authentic
"business_impact": "An attacker could potentially gain access to sensitive application internals, leadin
"raw": {
  "url": "https://juice-shop.herokuapp.com/debug",
  "status": 200,
  "path": "/debug"
}
},
{
  "id": "119b2dac-a56d-436f-8131-57f8f52f73d0",
  "title": "Information Disclosure in actuator:0",
  "file": "https://juice-shop.herokuapp.com/actuator",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Spring Boot Actuator endpoints are publicly accessible.",
  "rule_id": "sensitive-path-actuator",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /actuator \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The Spring Boot Actuator endpoints are publicly accessible, allowing an attacker to
"fix_suggestion": "To fix this vulnerability, add authentication or authorization to the /actuator endp

```

```

    "business_impact": "An attacker could use this vulnerability to gather sensitive information about the a
    "raw": {
      "url": "https://juice-shop.herokuapp.com/actuator",
      "status": 200,
      "path": "/actuator"
    }
  },
  {
    "id": "497599f4-6ce7-4b89-a4ef-fda3d46bb563",
    "title": "Information Disclosure in robots.txt:0",
    "file": "https://juice-shop.herokuapp.com/robots.txt",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "robots.txt may reveal hidden paths and sensitive directories.",
    "rule_id": "sensitive-path-robots.txt",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 28 bytes\nPreview: User-agent: *\nDis
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "MEDIUM",
    "category_source": "consistency_cache",
    "category_reason": "locked to historical category MEDIUM",
    "llm_explanation": "The presence of a robots.txt file may reveal sensitive directories, such as /ftp, wh
    "fix_suggestion": "Remove the robots.txt file or restrict its visibility to prevent sensitive informati
    "business_impact": "An attacker could use this information to gain unauthorized access to sensitive data
    "raw": {
      "url": "https://juice-shop.herokuapp.com/robots.txt",
      "status": 200,
      "path": "/robots.txt"
    }
  },
  {
    "id": "d67dd5c7-c8bc-4816-8705-0023e8a0568b",
    "title": "Information Disclosure in sitemap.xml:0",
    "file": "https://juice-shop.herokuapp.com/sitemap.xml",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "sitemap.xml may reveal internal URL structure.",
    "rule_id": "sensitive-path-sitemap.xml",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /sitemap.xml \u2192 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyr
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The sitemap.xml file reveals internal URL structure, potentially allowing an attacke
    "fix_suggestion": "Remove or restrict access to the sitemap.xml file (e.g., move it outside the document
    "business_impact": "An attacker could use this information to launch a targeted attack on the applicatio
    "raw": {
      "url": "https://juice-shop.herokuapp.com/sitemap.xml",
      "status": 200,
      "path": "/sitemap.xml"
    }
  },
  {
    "id": "4441828e-6101-4f28-9e31-30340db8c394",
    "title": "Information Disclosure in .DS_Store:0",
    "file": "https://juice-shop.herokuapp.com/.DS_Store",

```

```

"line_start": 0,
"line_end": null,
"severity": "MEDIUM",
"vuln_type": "INFORMATION_DISCLOSURE",
"description": "macOS .DS_Store file is publicly accessible \u2014 may reveal directory structure.",
"rule_id": "sensitive-path-.DS_Store",
"confidence": 0.85,
"cwe_id": "CWE-538",
"cvss_score": null,
"code_snippet": "GET /.DS_Store \u2019 HTTP 200\nContent-Length: 75002 bytes\nPreview: <!--\n ~ Copyright
"sources": [
  "url-scanner"
],
"risk_score": 0.3492,
"risk_category": "LOW",
"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The macOS .DS_Store file is publicly accessible, which may reveal the directory structure.",
"fix_suggestion": "Remove the .DS_Store file from the public directory by deleting it or moving it out.",
"business_impact": "An attacker could gather sensitive information about the directory structure and potentially access sensitive files.",
"raw": {
  "url": "https://juice-shop.herokuapp.com/.DS_Store",
  "status": 200,
  "path": "/.DS_Store"
}
},
{
  "id": "26530c7b-f6b3-44eb-9ad8-c8a18586bf81",
  "title": "Missing Security Header in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "MISSING_SECURITY_HEADER",
  "description": "Missing HTTP Strict-Transport-Security (HSTS) header. Without HSTS, browsers may allow downgrade attacks.",
  "rule_id": "header-missing-strict-transport-security",
  "confidence": 0.95,
  "cwe_id": "CWE-319",
  "cvss_score": null,
  "code_snippet": "Response headers: Strict-Transport-Security = (not set)",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3168,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The absence of an HTTP Strict-Transport-Security (HSTS) header allows attackers to perform downgrade attacks.",
  "fix_suggestion": "'file': 'https://juice-shop.herokuapp.com/#/', 'line': 0, 'code_change': 'Add HSTS header'",
  "business_impact": "Sensitive user data could be intercepted and used for further attacks, potentially leading to account hijacking.",
  "raw": {
    "url": "https://juice-shop.herokuapp.com/#/",
    "header": "Strict-Transport-Security",
    "check": "missing_header"
  }
},
{
  "id": "b365216c-5869-4a86-b6d0-22e11d769cde",
  "title": "Information Disclosure in :0",
  "file": "https://juice-shop.herokuapp.com/#/",
  "line_start": 0,
  "line_end": null,
  "severity": "LOW",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Missing Referrer-Policy header. Sensitive information in URLs may be leaked to third-party websites.",
  "rule_id": "header-missing-referrer-policy",
  "confidence": 0.8,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "Response headers: Referrer-Policy = (not set)",
  "sources": [

```

```
    "url-scanner"  
  ],  
  "risk_score": 0.2496,  
  "risk_category": "LOW",  
  "category_source": "score",  
  "category_reason": "score-threshold",  
  "llm_explanation": "The Referrer-Policy header is missing, which allows sensitive information in URLs to be leaked to third-party sites, potentially leading to account hijacking or data theft.",  
  "fix_suggestion": "{ 'file': 'https://juice-shop.herokuapp.com/#/', 'line': '0', 'code_change': '\"Add 'Referrer-Policy' header to the response.'\" }",  
  "business_impact": "Sensitive customer information could be leaked to third-party sites, potentially leading to account hijacking or data theft.",  
  "raw": {  
    "url": "https://juice-shop.herokuapp.com/#/",  
    "header": "Referrer-Policy",  
    "check": "missing_header"  
  }  
}  
]
```